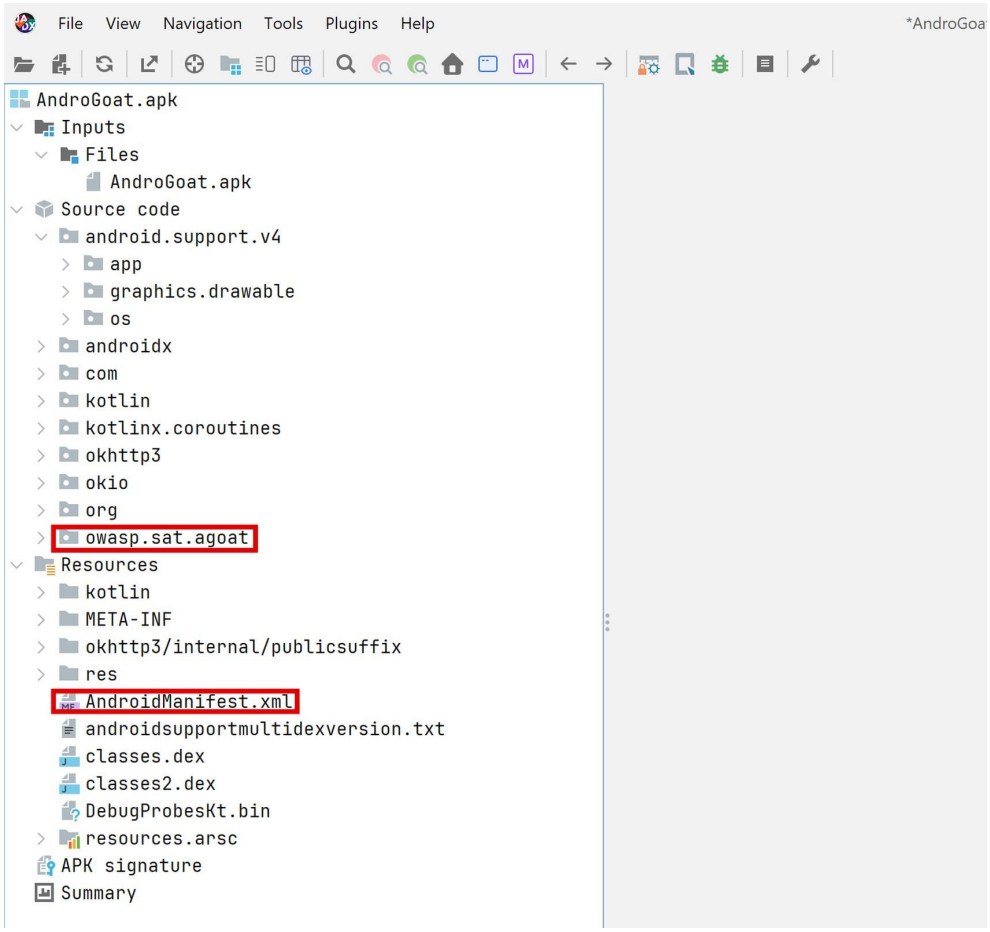
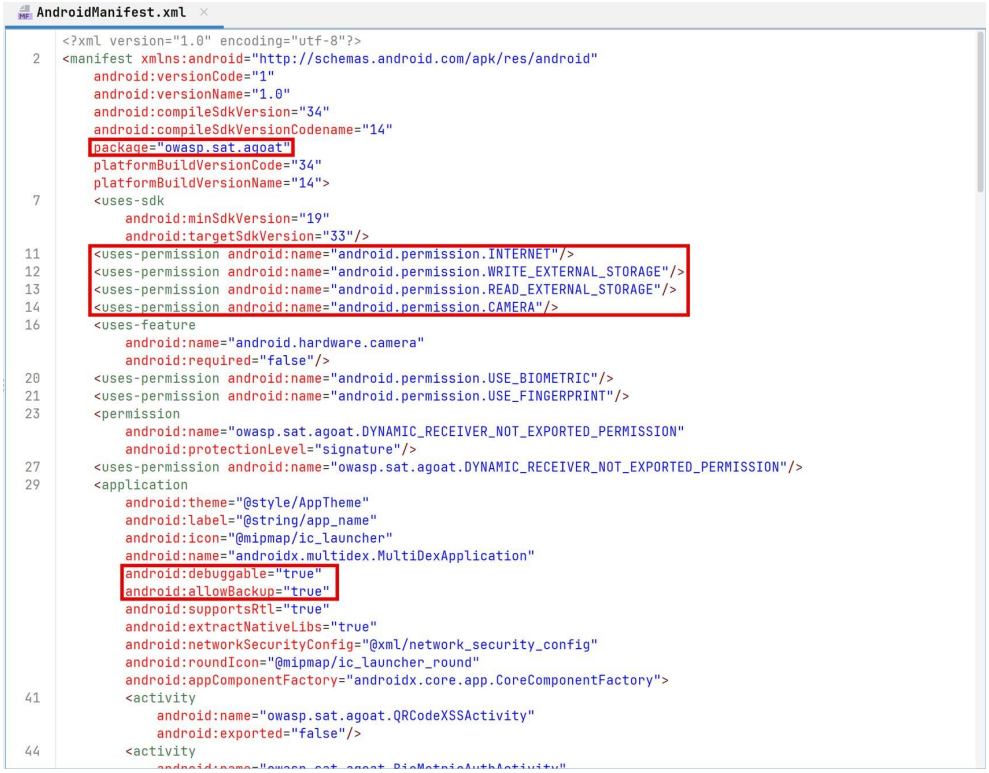
CASE:AndroGoat-Insecure_Storage-Riyad_Alshehri

- فتحت AndroGoat.apk في JADX-GUI ولاحظت إن كود التطبيق نفسه تحت الحزمة owasp.sat.agoat والباقي مكتبات جاهزة.

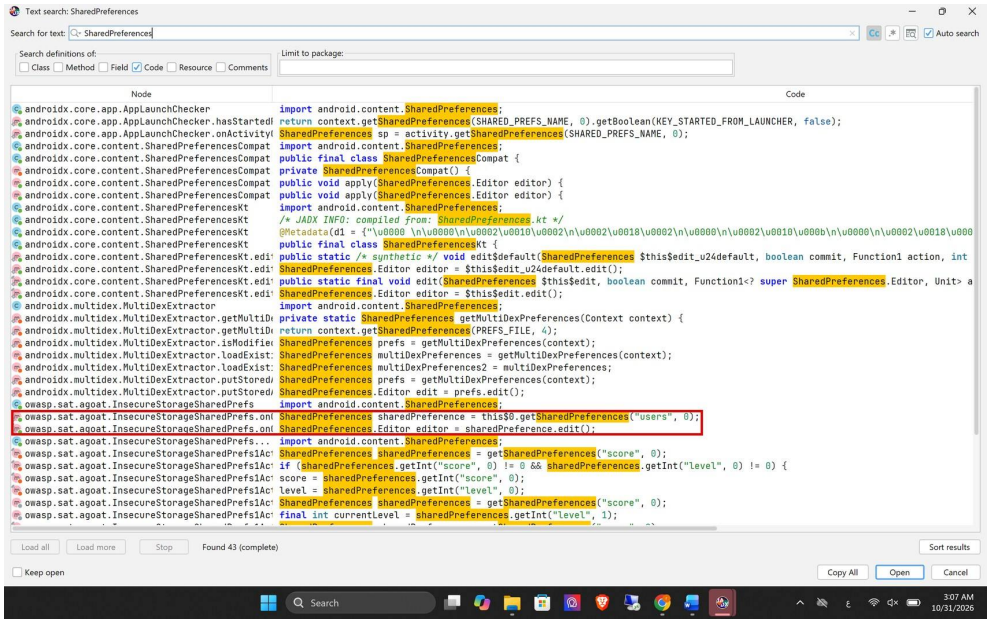


- فتحت AndroidManifest.xml وطلع اسم الحزمة owasp.sat.agoat والصلاحيات INTERNET و STORAGE و CAMERA ولاحظت إن debuggable و allowBackup قيمتهم true.



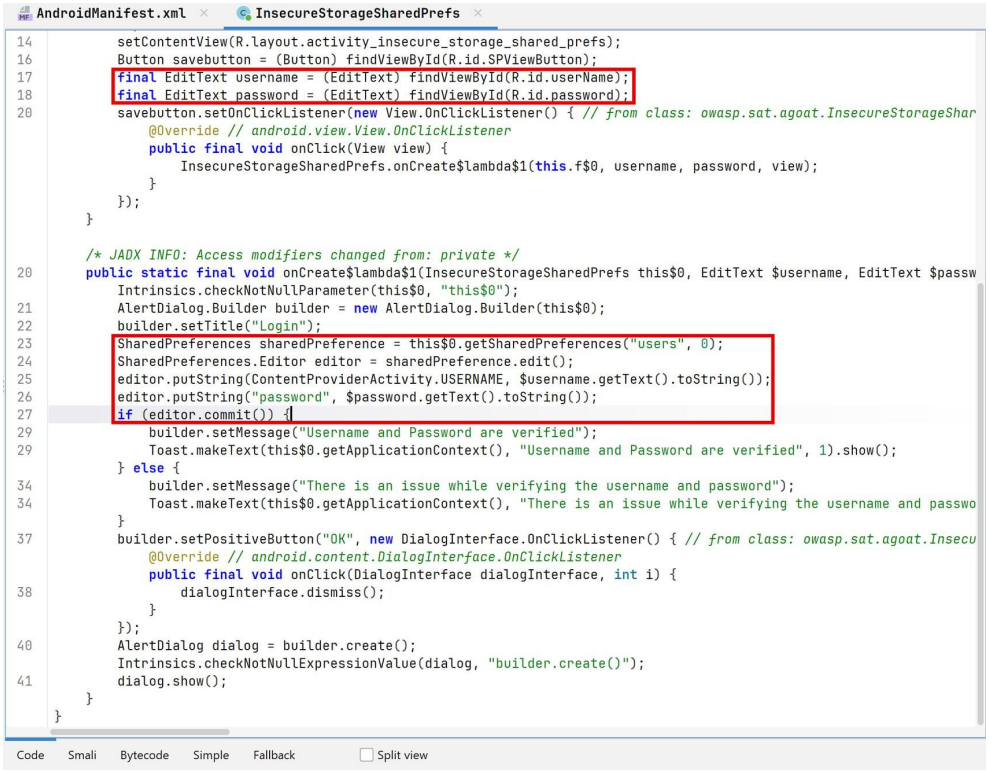
```
AndroidManifest.xml
<?xml version="1.0" encoding="utf-8"?>
<manifest xmlns:android="http://schemas.android.com/apk/res/android"
    android:versionCode="1"
    android:versionName="1.0"
    android:compileSdkVersion="34"
    android:compileSdkVersionCodename="14"
    package="owasp.sat.agoat"
    platformBuildVersionCode="34"
    platformBuildVersionName="14">
    <uses-sdk
        android:minSdkVersion="19"
        android:targetSdkVersion="33"/>
    <uses-permission android:name="android.permission.INTERNET"/>
    <uses-permission android:name="android.permission.WRITE_EXTERNAL_STORAGE"/>
    <uses-permission android:name="android.permission.READ_EXTERNAL_STORAGE"/>
    <uses-permission android:name="android.permission.CAMERA"/>
    <uses-feature
        android:name="android.hardware.camera"
        android:required="false"/>
    <uses-permission android:name="android.permission.USE_BIOMETRIC"/>
    <uses-permission android:name="android.permission.USE_FINGERPRINT"/>
    <permission
        android:name="owasp.sat.agoat.DYNAMIC_RECEIVER_NOT_EXPORTED_PERMISSION"
        android:protectionLevel="signature"/>
    <uses-permission android:name="owasp.sat.agoat.DYNAMIC_RECEIVER_NOT_EXPORTED_PERMISSION"/>
    <application
        android:theme="@style/AppTheme"
        android:label="@string/app_name"
        android:icon="@mipmap/ic_launcher"
        android:name="androidx.multidex.MultiDexApplication"
        android:debuggable="true"
        android:allowBackup="true"
        android:supportsRtl="true"
        android:extractNativeLibs="true"
        android:networkSecurityConfig="@xml/network_security_config"
        android:roundIcon="@mipmap/ic_launcher_round"
        android:appComponentFactory="androidx.core.app.CoreComponentFactory">
        <activity
            android:name="owasp.sat.agoat.QRCodeXSSActivity"
            android:exported="false"/>
        <activity
```

- بحثت عن SharedPreferences ولقيت الكلاس InsecureStorageSharedPrefs يفتح ملف اسمه users ويكتب فيه.



```
Text search: SharedPreferences
Search for text: SharedPreferences
Search definitions of: Class Method Field Code Resource Comments
Limit to package:
Node | Code
androidx.core.app.AppLaunchChecker                  import android.content.SharedPreferences;
androidx.core.app.AppLaunchChecker.hasStartedI      return context.getSharedPreferences(SHARED_PREFS_NAME, 0).getBoolean(KEY_STARTED_FROM_LAUNCHER, false);
androidx.core.app.AppLaunchChecker.onActivityC      SharedPreferences sp = activity.getSharedPreferences(SHARED_PREFS_NAME, 0);
androidx.core.content.SharedPreferencesCompat       import android.content.SharedPreferences;
androidx.core.content.SharedPreferencesCompat       public final class SharedPreferencesCompat {
androidx.core.content.SharedPreferencesCompat       private SharedPreferencesCompat() {
androidx.core.content.SharedPreferencesCompat       public void apply(SharedPreferences.Editor editor) {
androidx.core.content.SharedPreferencesCompat       public void apply(SharedPreferences.Editor editor) {
androidx.core.content.SharedPreferencesKt           import android.content.SharedPreferences;
androidx.core.content.SharedPreferencesKt           /* JADX INFO: compiled from: SharedPreferences.kt */
androidx.core.content.SharedPreferencesKt           @Metadata(d1 = {"\u0000 \n\u0000\n\u0002\u0010\u0002\n\u0002\u0018\u0002\n\u0000\n\u0002\u0010\u000b\n\u0000\n\u0002\u0018\u000
androidx.core.content.SharedPreferencesKt           public final class SharedPreferencesKt {
androidx.core.content.SharedPreferencesKt.edi       public static /* synthetic */ void edit$default(SharedPreferences $this$edit_u24default, boolean commit, Function1 action, int
androidx.core.content.SharedPreferencesKt.edi       SharedPreferences.Editor editor = $this$edit_u24default.edit();
androidx.core.content.SharedPreferencesKt.edi       public static final void edit(SharedPreferences $this$edit, boolean commit, Function1<? super SharedPreferences.Editor, Unit> a
androidx.core.content.SharedPreferencesKt.edi       SharedPreferences.Editor editor = $this$edit.edit();
androidx.multidex.MultiDexExtractor                 import android.content.SharedPreferences;
androidx.multidex.MultiDexExtractor.getMultiDe      private static SharedPreferences getMultiDexPreferences(Context context) {
androidx.multidex.MultiDexExtractor.getMultiDe      return context.getSharedPreferences(PREFS_FILE, 4);
androidx.multidex.MultiDexExtractor.isModifie       SharedPreferences prefs = getMultiDexPreferences(context);
androidx.multidex.MultiDexExtractor.loadExist       SharedPreferences multiDexPreferences = getMultiDexPreferences(context);
androidx.multidex.MultiDexExtractor.loadExist       SharedPreferences multiDexPreferences2 = multiDexPreferences;
androidx.multidex.MultiDexExtractor.putStored       SharedPreferences prefs = getMultiDexPreferences(context);
androidx.multidex.MultiDexExtractor.putStored       SharedPreferences.Editor edit = prefs.edit();
owasp.sat.agoat.InsecureStorageSharedPrefs          import android.content.SharedPreferences;
owasp.sat.agoat.InsecureStorageSharedPrefs.onC      SharedPreferences sharedPreference = this$0.getSharedPreferences("users", 0);
owasp.sat.agoat.InsecureStorageSharedPrefs.onC      SharedPreferences.Editor editor = sharedPreference.edit();
owasp.sat.agoat.InsecureStorageSharedPrefs...       import android.content.SharedPreferences;
owasp.sat.agoat.InsecureStorageSharedPrefs1Ac       SharedPreferences sharedPreferences = getSharedPreferences("score", 0);
owasp.sat.agoat.InsecureStorageSharedPrefs1Ac       if (sharedPreferences.getInt("score", 0) != 0 && sharedPreferences.getInt("level", 0) != 0) {
owasp.sat.agoat.InsecureStorageSharedPrefs1Ac       score = sharedPreferences.getInt("score", 0);
owasp.sat.agoat.InsecureStorageSharedPrefs1Ac       level = sharedPreferences.getInt("level", 0);
owasp.sat.agoat.InsecureStorageSharedPrefs1Ac       SharedPreferences sharedPreferences = getSharedPreferences("score", 0);
owasp.sat.agoat.InsecureStorageSharedPrefs1Ac       final int currentLevel = sharedPreferences.getInt("level", 1);
Load all | Load more | Stop | Found 43 (complete) | Sort results
Keep open | Copy All | Open | Cancel
```

- فتحت الكلاس ولقيته ياخذ اسم المستخدم وكلمة المرور من حقول الإدخال ويحفظها بـ putString مباشرة بدون تشفير.



- دخلت على USERNAME ولقيت قيمته username يعني البيانات تنحفظ بمفتاحين username و password.



الأسئلة:

- .1 ما اسم الكلاس والدالة التي تحفظ البيانات؟

الكلاس InsecureStorageSharedPrefs والدالة onCreate$lambda$1.

- .2 ما API التخزين المستخدم؟

SharedPreferences عن طريق getSharedPreferences("users", 0) و putString و commit.

- .3 ما الدليل على أن البيانات الحساسة تحفظ محليا؟ وهل تظهر بصيغة واضحة؟

الكود ياخذ النص من الحقول بـ getText().toString() ويحفظه بـ putString بدون تشفير فكلمة المرور تنحفظ واضحة في ملف users.xml.

- .4 ما الظروف التي قد تسمح بالوصول إلى البيانات؟

إذا كان الجهاز Root أو إذا أحد وصل للجوال بكابل لأن debuggable=true و allowBackup=true يسمحون بسحب ملفات التطبيق.

- .5 ما الإصلاح الأنسب؟ اذكر سببا لكل توصية.

- ما يحفظ كلمة المرور ويستخدم Token بدالها عشان ما يكون فيه شي ينسرق.

- يشفر البيانات بمفتاح في Android Keystore عشان ما تنقرى لو انسحب الملف.

- يخلي debuggable=false عشان يقفل الوصول عن طريق الكابل.

- يخلي allowBackup=false عشان ما تنسحب البيانات بالنسخ الاحتياطي.